



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Fake Microsoft Alerts Used to Deploy North Korean NarwhalRAT Malware

Malware Analysis Report

Classification	TLP:CLEAR
Published	2026-06-17
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis Report

TLP:CLEAR | Lost Boys Cyber | Fake Microsoft Alerts Used to Deploy North Korean NarwhalRAT Malware - Malware Analysis Report

Published: 2026-06-17 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review & Confidence
4. Initial Triage and Delivery Assessment
5. Static Analysis
6. Code Analysis
7. Dynamic Analysis
8. Process Tree and Execution Chain
9. Persistence and System Modification
10. Network and Infrastructure Analysis
11. Indicators of Compromise
12. MITRE ATT&CK Mapping
13. Detection Engineering
14. Threat Hunting
15. Triage and Incident Response
16. Validation and Emulation
17. Recommendations
18. References and Refresh Notes

Fake Microsoft Alerts Used to Deploy North Korean NarwhalRAT Malware

1. Executive Summary

Lost Boys Cyber assesses with medium-to-high confidence that the NarwhalRAT campaign described by Genians Security Center represents a North Korea-linked ScarCruft / APT37 espionage intrusion chain targeting Korean-language Windows users through Microsoft Account security-alert lures. The campaign uses a ZIP attachment containing a malicious LNK shortcut that impersonates a Microsoft one-time password abuse advisory. Execution chains through cmd.exe, PowerShell, curl.exe, a BAT script, the official Python embedded runtime, and compiled Python bytecode disguised as config.cat before loading the NarwhalRAT payload in memory.

The activity is operationally significant because the malware is not a simple commodity stealer. NarwhalRAT combines scheduled-task persistence, an in-memory Python ctypes loader, an encrypted local configuration store, multi-C2 relay infrastructure, pCloud API dead-drop resolver logic, and a manually operated command set for keylogging, screen capture, microphone recording, USB collection, file transfer, remote command execution, and C2 reconfiguration. The working-directory name naverwhale, Korean HWP decoy, KakaoTalk window filtering, Korean web relays, and similarity to prior Python-based APT37 activity all support Korean-targeted espionage rather than opportunistic crimeware.

No original sample was provided to Lost Boys Cyber for independent detonation or reverse engineering. This report is therefore source-backed rather than sample-backed. Static, code, dynamic, and process-chain sections separate directly reported Genians observations from Lost Boys Cyber detection and response assessment. Defenders should treat observed hits as a potential intrusion lead, not merely a malware-cleanup event, because the chain enables credential theft, surveillance, file collection, and operator-driven post-compromise actions.

Immediate defensive priorities are to detect archive-delivered LNK execution, PowerShell execution-policy bypass and copied curl.exe usage, suspicious downloads from webhostingkorea[.]com or related relays, Python embedded runtime installation under public/account-picture themed directories, one-minute scheduled-task execution of userscreen.exe config.cat, creation of %APPDATA%\naverwhale, pCloud API access from unusual endpoints, and communications to the listed Korean relay infrastructure.

Finding	Analyst Assessment	Defensive Implication
Microsoft Account OTP lure delivered ZIP/LNK	High-confidence reported initial access vector	Reinforce attachment controls, LNK extraction detonation, and phishing triage playbooks
Multi-stage Python loader	High-confidence reported execution chain	Correlate cmd, PowerShell, curl, tar, Python runtime, and scheduled-task telemetry rather than relying on file hashes only
NarwhalRAT in-memory payload	Medium confidence from vendor reverse engineering	Memory, process, and behavior telemetry are required; disk-only AV controls may miss the final component
Multi-C2 and pCloud dead-drop logic	High-confidence reported C2 design	Block/monitor known relays and inspect anomalous pCloud API use by unmanaged Python processes
Korean targeting signals	Medium-to-high confidence assessment	Prioritize Korean-language users, Korea-facing business units, defense/crypto exposure, and KakaoTalk/HWP-heavy environments

2. Sample Metadata

Field	Value
Family	NarwhalRAT
Malware Type	Python-staged remote access trojan / espionage backdoor
Assessed Threat Actor	ScarCruft / APT37, North Korea-linked; attribution inherited from Genians and The Hacker News reporting
Platform	Microsoft Windows
Primary Sample SHA256	Not published in available reporting; MD5 values are listed in the IOC section
Additional Hashes	MD5: 3715092aa00f380cefe8b4d2eddb7d08; 7cef19f9c4480adac0cd4702ff98f46c; 7eb9cee1f696727752169f25cf79a338; b6b0602310bb2d4360c52685119aac1b
File Type / Format	ZIP archive; LNK shortcut; BAT script; Python embedded runtime ZIP; compiled Python bytecode disguised as .cat; in-memory PE payload
Delivery Theme	Fake Microsoft Account security notice about repeated OTP generation / account compromise
First Seen / Reported	Genians analysis published 2026-06-14; The Hacker News summarized 2026-06-16
Analyst Confidence	Medium overall; high for reported infection chain and IOCs; medium for attribution and unseen sample internals
Primary Objective	Espionage-oriented remote access, information theft, surveillance, USB/file collection, and operator-driven command execution
Source Basis	Vendor technical report plus secondary media coverage; no original binary supplied to Lost Boys Cyber

3. Source Review & Confidence

Source	Contribution	Confidence	Notes
Genians Security Center, Analysis of APT37 NarwhalRAT Leveraging MS-Themed Phishing and Dead-drop C2	Primary technical source for delivery flow, loader behavior, C2 design, commands, persistence, and IOCs	High for reported observations	Source includes reverse-engineering detail and IOC list but Lost Boys Cyber did not receive raw samples
The Hacker News, Fake Microsoft Alerts Used to Deploy North Korean NarwhalRAT Malware	Secondary summary and broader public awareness	Medium	Useful for intake validation and executive-level framing; not a substitute for primary report
Lost Boys Cyber analytic synthesis	Detection, hunting, IR, and risk interpretation	Medium	Derived from cited source facts and standard Windows/EDR

		telemetry patterns
--	--	--------------------

Directly observed in source reporting: malicious Microsoft-themed email, ZIP/LNK delivery, PowerShell and BAT staging, use of curl/tar/schtasks, Python embedded runtime installation, config.cat Python bytecode, scheduled task named MicrosoftUserInterfacePicturesUpdateTaskMachine, %APPDATA%\naverwhale working directory, pCloud API logic, default C2 URLs, command prefixes, and listed MD5/domain/IP indicators.

High-confidence assessment: the chain is built for stealthy operator-controlled espionage and data collection, not smash-and-grab commodity theft. The use of official Python distribution, legitimate Windows binaries, scheduled tasks, cloud API dead-end logic, and local encrypted state increases dwell time and resiliency.

Lower-confidence inference: the ScarCraft/APT37 attribution and exact targeting set are inherited from primary reporting. Lost Boys Cyber did not independently validate actor infrastructure ownership, victimology, compiler artifacts, or raw binary lineage.

4. Initial Triage and Delivery Assessment

The initial lure is a spear-phishing message displayed as sent by Microsoft Account Team and titled approximately [Urgent] Security Check Notice Regarding Repeated One-Time Password (OTP) Generation. The body warns about abnormal OTP generation and directs the recipient to review an attached security advisory. Reporting states that the sender domain was unrelated to official Microsoft infrastructure, and the attachment was a ZIP archive rather than a legitimate document.

The ZIP archive reportedly contains Cybersecurity Advisory Notice (Regarding One-Time Password Abuse).lnk. The shortcut name and decoy flow are designed to make the user believe they are opening a security notice. Internally, the LNK command reconstructs hidden command strings from CMD environment-variable substring operations, then invokes PowerShell with ExecutionPolicy Bypass and stages additional content through copied curl.exe.

Variant / Artefact	Delivery Role	Notes
Spear-phishing email	Initial access lure	Microsoft Account security alert impersonation centered on OTP abuse anxiety
Cybersecurity Advisory Notice (Regarding One-Time Password Abuse).zip	Attachment / downloaded archive	Delivered through fe01.co[.]kr according to Genians
Cybersecurity Advisory Notice (Regarding One-Time Password Abuse).lnk	User-executed shortcut	Obfuscated CMD substring reconstruction hides PowerShell/curl logic
Decoy HWP document	User deception	Downloaded to %TEMP% to satisfy user expectation of an advisory document
KHjWFcsE.bat	Second-stage installer	Downloads Python runtime, creates disguised runtime directory, retrieves config.cat, registers persistence
Python-3.10.0-embed-amd64.zip	Legitimate runtime dependency	Pulled from official Python distribution to reduce suspicion and avoid bundling interpreter
config.cat	Malicious Python bytecode payload	Disguised as Windows catalog file but identified as compiled Python bytecode

5.1 File and Build Characteristics

No raw sample was available for Lost Boys Cyber hashing, entropy checks, PE header inspection, or independent packer analysis. The following static findings are derived from Genians reverse engineering and command-line analysis.

Static Signal	Evidence	Analyst Value
---------------	----------	---------------

LNK with obfuscated internal command	CMD environment variable substring substitution reconstructs powershell, ExecutionPolicy, Bypass, Command, Start-Process, and curl.exe	Detects initial execution without relying on sample hashes
Copied curl.exe path anomaly	Reported destination concatenation creates a path similar to C: \Users\<USER>\AppData\Local\TempuAR KK20.exe rather than %TEMP% \uARKK20.exe	High-signal staging artifact and LOLBin abuse clue
BAT command obfuscation	KHjWFcsE.bat uses a random string variable and substring extraction to reconstruct commands	Supports detection of BAT-based obfuscation following LNK execution
Python embedded runtime	Python-3.10.0-embed-amd64.zip downloaded from official Python host and extracted to C: \Users\Public\AccountPictures\UserInterfacePicture	Legitimate dependency abused to host malicious bytecode
Renamed interpreter	Pythonw.exe renamed to userscreen.exe	Reduces visible console activity and disguises process as a user-interface component
Disguised bytecode	config.cat begins with Python bytecode magic bytes 6F 0D 0D 0A and code-object marker 0xE3	Useful for YARA/static triage of .cat files that are actually .pyc payloads
In-memory payload staging	Python loader uses ctypes to call Windows APIs and execute decrypted payload in memory	Explains why final malicious behavior may appear under a benign-looking Python process
Working directory mimicry	%APPDATA%\naverwhale with Hidden and System attributes	Korean-targeting signal and host artifact for triage

5.2 Strings, Imports, and Embedded Artefacts

The available reporting identifies multiple strings and modules of operational value. The first Python bytecode stage indirectly imports modules through `getattr(__builtins__, "__import__")` rather than explicit import statements. Reported modules include `os`, `base64`, `urllib.request`, `urllib.parse`, `sys`, and `io`. Key strings such as C2 URLs, Cookie, User-Agent, data, and utf-8 are reconstructed rather than left plainly visible.

Strings and artefacts defenders should hunt for include:

String / Artefact	Context
naverwhale	NarwhalRAT working directory under %APPDATA%
UserInterfacePicture	Misspelled public account-picture themed runtime path
userscreen.exe	Renamed Pythonw.exe interpreter used by scheduled task
config.cat	Python bytecode payload disguised as catalog file
MicrosoftUserInterfacePicturesUpdateTackMachine	Reported scheduled-task name; note the unusual TackMachine

	spelling
startkcap:, startscap:, usb2local:, cmd:, cmdadm:	Reported command prefixes used by RAT command dispatcher
folderid=, auth=, api.pcloud.com	pCloud API dead-drop resolver logic
KakaoTalkEdgeWnd, KakaoTalkShadowWnd	Window filtering logic suggesting Korean user-environment awareness
C:\Users\Public\AccountPictures\UserInterfacePicture	Staged Python runtime directory
%LOCALAPPDATA%\Microsoft\Internet Explorer	Disguised configuration storage path for encrypted .ent state

5.3 Static Configuration Clues

Genians reports that NarwhalRAT uses a global configuration area of approximately 1,700 bytes to store C2 addresses, communication password, pCloud settings, upload paths, and feature flags. If no local .ent configuration file exists, the malware falls back to default C2 values hardcoded in the binary.

Reported default management/data C2 URLs:

Default URL	Role / Assessment
hxxp://www.daehoat[.]com/wp-content/uploads/2017/02/member.php	Default C2 relay / management endpoint
hxxp://www.novel21[.]co.kr/data/editor/2110/index.php	Default C2 relay / data or alternate endpoint

The local configuration is reported to be AES-128 encrypted through Windows CryptoAPI. The hardcoded string !221aeAescde##2aefseseppl^12 is used as key material, derived through SHA-256 and CryptDeriveKey rather than used directly as the AES key. This finding is valuable for reverse engineers attempting configuration recovery from memory or from local .ent artifacts.

6.1 Reverse-Engineering Method

Lost Boys Cyber did not receive raw binaries and did not perform Ghidra, radare2, or sandbox analysis for this task. Code-analysis findings below are taken from Genians decompilation and are assessed for defensive use. The strongest independently actionable elements are command-line behaviors, file paths, scheduled-task parameters, command prefixes, and network indicators.

6.2 Functions and Logic of Interest

Function / Routine	Evidence	Why It Matters
LNK command reconstruction	Environment variable substring substitution hides PowerShell and curl strings	Bypasses simple static signature matching and complicates email gateway inspection
BAT installer	Downloads official Python, extracts runtime with tar, renames Pythonw.exe, downloads config.cat	Establishes a living-off-the-land staging environment rather than dropping a single obvious EXE
Scheduled-task persistence	schtasks runs userscreen.exe config.cat every minute	Ensures repeated execution and provides a reliable host-based detection point
Python bytecode loader	config.cat communicates with webhostingkorea[.]com, receives command code, downloads additional BAT files	Bridges the installer stage to later operator-controlled payload retrieval
Bytecode decryption	Base64 payload, first 16 decoded bytes as salt, seed aHAnLLtQrP8Ce, SHA-256	Enables concealed payload storage and

	counter keystream, XOR decryption	complicates payload recovery
ctypes in-memory execution	Python calls Windows APIs and executes decrypted payload in the Python process	Final payload may not be written as a normal PE file on disk
Hypervisor checks	CPUID-based hypervisor vendor ID checks for VMware, VirtualBox, and other virtualized environments	Indicates anti-analysis and may suppress or alter behavior in sandboxes
Working-directory setup	Creates %APPDATA%\naverwhale and sets Hidden/System attributes	Stores collected data and blends with Naver Whale browser naming
Encrypted state persistence	Creates encrypted .ent configuration below %LOCALAPPDATA%\Microsoft\Internet Explorer	Restores C2 values and feature activation flags after reboot
Prefix-based command dispatcher	More than 30 command prefixes for screen capture, keylogging, microphone, USB, remote command, file transfer, remote click, and C2 changes	Confirms manually operated RAT architecture

6.3 Anti-Analysis, Evasion, and Obfuscation

NarwhalRAT and its staging chain combine several evasion layers:

- Social engineering: Microsoft Account OTP security alert theme and security-advisory filename.
- Archive-delivered LNK: hides command execution behind a document-like shortcut.
- CMD substring obfuscation: reconstructs commands at runtime from random string variables.
- PowerShell policy bypass: explicitly uses ExecutionPolicy Bypass.
- LOLBin staging: uses copied curl.exe, tar, schtasks, and official Python distribution rather than obvious malware tooling.
- Extension masquerading: config.cat is Python bytecode, not a Windows catalog file.
- Interpreter renaming: Pythonw.exe becomes userscreen.exe.
- Hidden/System working directory: %APPDATA%\naverwhale is hidden from casual inspection.
- Encrypted local configuration: C2 and feature flags persist in encrypted .ent data.
- In-memory execution: final payload runs from the Python process via ctypes and Windows APIs.
- Virtualization awareness: CPUID hypervisor checks may affect sandbox visibility.
- Cloud API routing: pCloud API dead-drop resolver logic can blend with legitimate cloud traffic.

7.1 Execution Overview

Reported execution proceeds as follows: the victim executes the LNK from the ZIP archive; the LNK reconstructs and runs an obfuscated command through cmd.exe and PowerShell; PowerShell uses copied curl.exe to fetch a decoy HWP and KHjWFcsE.bat from webhostingkorea[.]com; the BAT downloads the official Python embedded runtime, extracts it below C:\Users\Public\AccountPictures\UserInterfacePicture, renames Pythonw.exe to userscreen.exe, retrieves config.cat, and creates a scheduled task to run the bytecode through the renamed interpreter every minute.

Once config.cat runs, it communicates with C2 infrastructure, retrieves command code or additional BAT content, decrypts an embedded payload using Base64/SHA-256/XOR logic, and uses Python ctypes to execute the final NarwhalRAT payload in memory. The final payload prepares host state, creates a working directory, restores or initializes encrypted configuration, communicates with relay infrastructure and pCloud dead-drop logic, and waits for operator commands.

7.2 Filesystem, Registry, Service, and Task Changes

Artefact	Type	Reported Behavior	Defensive Value
----------	------	-------------------	-----------------

C:\Users\Public\AccountPictures\UserInterfacePicture	Directory	Python embedded runtime extraction path	High-signal because of misspelling and unusual interpreter placement
userscreen.exe	File / process	Renamed Pythonw.exe	Detect Python interpreter masquerading as UI component
config.cat	File	Python bytecode payload disguised as catalog file	Search for .cat files with Python bytecode magic bytes
MicrosoftUserInterfacePicturesUpdateTaskMachine	Scheduled task	Runs userscreen.exe config.cat every minute	Strong persistence indicator
%APPDATA%\naverwhale	Directory	Hidden/System working directory for collected data	Strong triage target and Korean-targeting clue
%LOCALAPPDATA%\Microsoft\Internet Explorer*.ent	Encrypted config	Stores C2 addresses, password, feature flags	Potential config-recovery and persistence-state artifact
%TEMP%\Cybersecurity Advisory Notice (Regarding One-Time Password Abuse).hwp	Decoy document	Opened to satisfy user expectations	Supports timeline reconstruction
C:\Users\Public\<random>	Staging path	USB collection copies data via xcopy into public random path	Triage for removable-media collection

7.3 Network and Command-and-Control Behaviour

The chain uses both relay infrastructure and a cloud-service dead-drop pattern. During staging, webhostingkorea[.]com is used to retrieve the HWP decoy, BAT script, and config.cat. NarwhalRAT then uses default C2 URLs on daehoat[.]com and novel21[.]co.kr, with additional infrastructure listed in the IOC section. Genians also identified pCloud API code that handles folderid= and auth= parameters and branches on api.pcloud[.]com, indicating a legitimate cloud storage service may deliver or resolve operational data.

Network Signal	Role	Stability / Confidence	Notes
fe01.co[.]kr	Archive relay	Medium / reported	Used to download ZIP containing LNK
webhostingkorea[.]com	Staging C2 / download relay	High / reported	Downloads decoy HWP, BAT, and config.cat
daehoat[.]com	Default C2 relay	High / reported	Hardcoded default URL path reported by Genians
novel21[.]co.kr	Default C2 relay	High / reported	Hardcoded default URL path reported by Genians
crwellfood[.]com	C2 / related infrastructure	Medium / reported	Listed IOC; exact role not fully described in public text
api.pcloud[.]com	Dead-drop resolver / cloud API	High / code-reported	Monitor anomalous pCloud API use from Python or compromised hosts

7.4 Observed Capability Summary

Capability	Supporting Dynamic Evidence
Remote command execution	Command prefixes cmd: and cmdadm: and more than 30-prefix command dispatcher
Keylogging	startkcap: style key-capture command family; local storage under %APPDATA%\naverwhale before upload
Screen capture	startscap: / endscap: activation pattern reported by Genians
Microphone recording	Reported command capability and feature flag persistence
USB collection	usb2local: command generates xcopy /s /e /y /c /q /h /b collection command
File upload/download	Reported RAT command categories and upload-path configuration
Remote clicking / interactive control	Reported command-control function category
C2 reconfiguration	cmserver:, caserver:, and cdserver: command prefixes change C2 addresses
Local state persistence	AES-128 encrypted .ent configuration stores feature flags, passwords, and C2 values

8. Process Tree and Execution Chain

Step	Parent Process	Child / Action	Why It Matters
1	Email client / user shell	User opens ZIP and executes LNK	Establishes phishing-to-execution timeline
2	explorer.exe	cmd.exe /k with obfuscated LNK command	LNK shortcut becomes script execution, not document viewing
3	cmd.exe	powershell.exe -ExecutionPolicy Bypass	Bypasses local script policy and begins staged download logic
4	powershell.exe	Copied curl.exe from C:\Windows\System32\curl.exe to local disguised path	LOLBin abuse and command-line detection opportunity
5	curl.exe / PowerShell	Downloads decoy HWP and KHjWFcsE.bat from webhostingkorea[.]com	Separates user-facing decoy from real installer
6	powershell.exe	Executes KHjWFcsE.bat hidden	Hands off from shortcut to installer script
7	KHjWFcsE.bat	curl downloads Python-3.10.0-embed-amd64.zip; tar extracts runtime	Abuse of legitimate runtime and tooling

8	KHjWFcsE.bat	Renames Pythonw.exe to userscreen.exe; downloads config.cat	Establishes disguised Python execution environment
9	KHjWFcsE.bat / schtasks.exe	Creates MicrosoftUserInterfacePicturesUpdateTackMachine scheduled task	Persistence and repeated payload execution
10	Task Scheduler	userscreen.exe config.cat every minute	Runtime parent for malicious Python bytecode
11	userscreen.exe	Python bytecode communicates with C2, decrypts payload, executes in memory via ctypes	Final NarwhalRAT activity may appear inside Python process memory
12	NarwhalRAT in Python process	Creates %APPDATA%\naverwhale, reads/writes encrypted .ent state, receives commands	Data collection, C2, and persistence-state operations

9. Persistence and System Modification

NarwhalRAT uses Task Scheduler rather than a Run key or service for repeated execution. The staging script registers a task named MicrosoftUserInterfacePicturesUpdateTackMachine, configured to execute C:

\Users\Public\AccountPictures\UserInterfacePicture\userscreen.exe with config.cat in the same directory at one-minute intervals. The name appears intended to blend into Microsoft account-picture or user-interface maintenance activity, although the TackMachine spelling anomaly is notable.

Modification Type	Artefact	Evidence	Confidence
Scheduled task	MicrosoftUserInterfacePicturesUpdateTackMachine	Reported by Genians; runs userscreen.exe config.cat every minute	High
Runtime directory	C:\Users\Public\AccountPictures\UserInterfacePicture	BAT extraction path for official Python embedded runtime	High
Interpreter masquerading	userscreen.exe renamed from Pythonw.exe	Reported installer behavior	High
Payload masquerading	config.cat compiled Python bytecode	Header magic bytes and decompilation reported	High
Working directory	%APPDATA%\naverwhale with Hidden/System attributes	Created by NarwhalRAT final payload	High
Configuration persistence	.ent file under %LOCALAPPDATA%\Microsoft\Internet Explorer	AES-encrypted state holds C2 and feature flags	Medium-to-high
Data staging	%APPDATA%\naverwhale and C:\Users\Public\<random>	Used for keylogs/screenshots/audio/upload queue and USB collection	Medium

10. Network and Infrastructure Analysis

NarwhalRAT's infrastructure model is designed for resilience. The first stage uses relay infrastructure to deliver a decoy, installer script, and Python bytecode. The final payload restores C2 settings from encrypted local state when present, otherwise uses hardcoded defaults. It can update management, data, and alternative C2 values through operator commands. pCloud API logic provides a secondary dead-drop resolver path, allowing operators to use legitimate cloud infrastructure for discovery, command delivery, or data exchange.

IOC / Infrastructure	Type	Role	Stability / Confidence
fe01.co[.]kr	Domain	ZIP/LNK delivery relay	Medium; reported delivery infrastructure
webhostingkorea[.]com	Domain	Decoy, BAT, config.cat staging relay	High; staging path described
daeloat[.]com	Domain	Default C2 relay	High; hardcoded default endpoint described
novel21.co[.]kr	Domain	Default C2 relay	High; hardcoded default endpoint described
crwellfood[.]com	Domain	Related C2 infrastructure	Medium; IOC listed with limited context
api.pcloud[.]com	Domain	Cloud dead-drop resolver / C2 support	High for code path; operational accounts unknown
121.254.222[.]10	IP address	Listed C2 / related infrastructure	Medium; IOC listed
121.254.222[.]80	IP address	Listed C2 / related infrastructure	Medium; IOC listed
211.239.157[.]126	IP address	Listed C2 / related infrastructure	Medium; IOC listed
218.150.78[.]198	IP address	Listed C2 / related infrastructure	Medium; IOC listed
218.150.78[.]231	IP address	Listed C2 / related infrastructure	Medium; IOC listed
61.100.9[.]206	IP address	Listed C2 / related infrastructure	Medium; IOC listed

Blocking these indicators is appropriate for immediate containment, but mature defenses should emphasize behavior: LNK-to-PowerShell execution, curl/tar/schtasks staging, Python runtime installation in public profile paths, disguised .cat bytecode, scheduled one-minute execution, pCloud API use from unmanaged Python processes, and naverwhale data staging.

11. Indicators of Compromise

The IOC set below is normalized from Genians public reporting. It should be treated as a minimum seed set rather than complete infrastructure coverage. Domains have been defanged in narrative form; the accompanying iocs.csv stores operational indicator values with descriptions and confidence.

IOC Type	Example / Count	Source	Operational Notes
MD5	4 values	Genians	Useful for retro-hunting if

			samples are collected; SHA256 values were not available in public text
Domains	5 malicious/related domains plus pCloud API behavior	Genians	Prioritize webhostingkorea[.]com, daehoat[.]com, novel21.co[.]kr; pCloud requires contextual detection
IP Addresses	6 values	Genians	Investigate historical connections from affected Windows endpoints
File paths / names	userscreen.exe, config.cat, naverwhale, UserInterfacePicture	Genians / LBC synthesis	High-value host triage artifacts
Scheduled task	MicrosoftUserInterfacePictures UpdateTackMachine	Genians	Strong persistence signal
Command prefixes	startkcap:, startscap:, usb2local:, cmd:, cmdadm:, cmserver:, caserver:, cdserver:	Genians	Useful for memory, decrypted config, and network-content inspection where legally/technically available
Value	Type	Context	
3715092aa00f380cefe8b4d2eddb7d08	MD5	Reported NarwhalRAT campaign artifact	
7cef19f9c4480adac0cd4702ff98f46c	MD5	Reported NarwhalRAT campaign artifact	
7eb9cee1f696727752169f25cf79a338	MD5	Reported NarwhalRAT campaign artifact	
b6b0602310bb2d4360c52685119aac1b	MD5	Reported NarwhalRAT campaign artifact	
crwellfood[.]com	Domain	Reported C2 / related infrastructure	
daehoat[.]com	Domain	Default C2 relay	
fe01.co[.]kr	Domain	ZIP archive relay	
novel21.co[.]kr	Domain	Default C2 relay	
webhostingkorea[.]com	Domain	Staging relay	
121.254.222[.]10	IP address	Reported C2 / related infrastructure	
121.254.222[.]80	IP address	Reported C2 / related infrastructure	
211.239.157[.]126	IP address	Reported C2 / related infrastructure	
218.150.78[.]198	IP address	Reported C2 / related infrastructure	
218.150.78[.]231	IP address	Reported C2 / related infrastructure	
61.100.9[.]206	IP address	Reported C2 / related infrastructure	

12. MITRE ATT&CK Mapping

Technique	Name	Evidence
T1566.001	Phishing: Spearphishing Attachment	Microsoft Account security-alert lure with ZIP/LNK attachment
T1204.002	User Execution: Malicious File	Recipient executes advisory-themed LNK file
T1027	Obfuscated Files or Information	CMD/BAT substring obfuscation, reconstructed strings, reversed strings, char-by-char construction
T1059.001	Command and Scripting Interpreter: PowerShell	PowerShell ExecutionPolicy Bypass used during staging
T1059.003	Command and Scripting Interpreter: Windows Command Shell	cmd.exe /k and BAT stages drive execution
T1059.006	Command and Scripting Interpreter: Python	Python embedded runtime executes compiled bytecode payload
T1105	Ingress Tool Transfer	curl downloads decoy HWP, BAT, Python runtime, and config.cat
T1218	System Binary Proxy Execution	Abuse of legitimate Windows binaries and renamed interpreter; curl/tar/schtasks support staging
T1053.005	Scheduled Task/Job: Scheduled Task	MicrosoftUserInterfacePicturesUpdateTask Machine runs every minute
T1036.005	Masquerading: Match Legitimate Name or Location	userscreen.exe, config.cat, UserInterfacePicture, naverwhale, Internet Explorer config path
T1620	Reflective Code Loading	Python ctypes executes decrypted payload in memory
T1497.001	Virtualization/Sandbox Evasion: System Checks	CPUID hypervisor vendor ID checks for VMware/VirtualBox
T1056.001	Input Capture: Keylogging	Operator-controlled keylogging functions and local keylog staging
T1113	Screen Capture	startscap-style command and screen capture feature flags
T1123	Audio Capture	Microphone recording capability reported
T1005	Data from Local System	File and local data collection under working directory
T1025	Data from Removable Media	usb2local command copies removable storage data with xcopy
T1119	Automated Collection	Data collection functions store content

		before upload
T1102.002	Web Service: Bidirectional Communication	pCloud API and web relay C2 paths
T1573.001	Encrypted Channel: Symmetric Cryptography	AES-128 encrypted local configuration and password/C2 state
T1071.001	Application Layer Protocol: Web Protocols	HTTP relay endpoints and pCloud API communication
T1041	Exfiltration Over C2 Channel	Collected data uploaded through RAT C2 routines

13.1 Detection Logic Summary

Signal	Telemetry Source	Analytic Goal	Tuning Notes
LNK spawns cmd/PowerShell with ExecutionPolicy Bypass	EDR process creation, Sysmon Event ID 1, Windows 4688	Catch malicious shortcut execution chain	Exclude known software deployment scripts only after parent path and archive context are reviewed
PowerShell copies or executes curl from a user/temp-like path	EDR/Sysmon process and file events	Detect copied LOLBin staging	Tune for enterprise package managers that legitimately stage curl
Python embedded runtime under public AccountPictures path	File creation and process execution	Detect NarwhalRAT runtime installation	Very low expected baseline; treat misspelled UserInterfacePicture as high confidence
Scheduled task named MicrosoftUserInterfacePictures UpdateTackMachine	Security 4698, TaskScheduler Operational 106/140, EDR	Detect persistence	Task name spelling is highly suspicious
userscreen.exe executes config.cat	Process command line and file metadata	Detect disguised Pythonw interpreter running bytecode	Validate file hash and parent task context
.cat file with Python bytecode magic	File scanning/YARA	Detect masqueraded Python payloads	Legitimate .cat files should not begin with Python .pyc magic bytes
%APPDATA%\naverwhale creation with Hidden/System attributes	File events	Detect final RAT working directory	Naver Whale installs should not normally create this exact hidden appdata path for data staging
pCloud API access by renamed/unmanaged Python process	Proxy/DNS/EDR network telemetry	Detect dead-drop resolver behavior	Tune for sanctioned pCloud users and known automation hosts
Known relay domains/IPs	DNS, proxy, firewall, EDR network	Immediate IOC detection	Infrastructure may age quickly; pair with behavior detections

13.2 Detection Content

title: NarwhalRAT LNK to PowerShell Staging Chain id: 26922642-b35b-4a2a-9d66-f6d696d0e026 status: experimental

```

description: Detects a shortcut or shell-spawned PowerShell chain using execution-policy bypass and
curl staging consistent with reported NarwhalRAT delivery.
author: Lost Boys Cyber
date: 2026-06-17
references:
  - https://www.genians.co.kr/en/blog/threat_intelligence/narwhalrat
  - https://thehackernews.com/2026/06/fake-microsoft-alerts-used-to-deploy.html
logsource:
  product: windows
  category: process_creation
detection:
  selection_parent:
    ParentImage|endswith:
      - '\explorer.exe'
      - '\cmd.exe'
      - '\powershell.exe'
  selection_powershell:
    Image|endswith:
      - '\powershell.exe'
      - '\pwsh.exe'
    CommandLine|contains|all:
      - 'ExecutionPolicy'
      - 'Bypass'
  selection_curl:
    CommandLine|contains:
      - 'curl.exe'
      - 'webhostingkorea'
      - 'config.cat'
      - 'KHjWFcsE.bat'
  condition: selection_parent and (selection_powershell or selection_curl)
falsepositives:
  - Administrative scripts that explicitly bypass policy and download internal content
level: high
tags:
  - attack.t1566.001
  - attack.t1204.002
  - attack.t1059.001
  - attack.t1105

```

```

title: NarwhalRAT Scheduled Task Persistence
id: 9f311811-4557-4d5d-91cd-f5a1d2350e5a
status: experimental
description: Detects the reported NarwhalRAT scheduled task and disguised Python runtime execution
path.
author: Lost Boys Cyber
date: 2026-06-17
references:
  - https://www.genians.co.kr/en/blog/threat_intelligence/narwhalrat
logsource:
  product: windows
  category: process_creation
detection:
  selection_schtasks:
    Image|endswith: '\schtasks.exe'
    CommandLine|contains:
      - 'MicrosoftUserInterfacePicturesUpdateTackMachine'
      - 'UserInerfacePicture'
      - 'userscreen.exe'
      - 'config.cat'
  selection_runtime:
    Image|endswith: '\userscreen.exe'
    CommandLine|contains|all:
      - 'UserInerfacePicture'
      - 'config.cat'
  condition: selection_schtasks or selection_runtime
falsepositives:

```



```

- Unlikely; investigate any exact task name or path hit
level: critical
tags:
- attack.t1053.005
- attack.t1036.005
- attack.t1059.006

```

```

rule MAL_NarwhalRAT_Masqueraded_Python_Bytecode_Cat
{
  meta:
    author = "Lost Boys Cyber"
    date = "2026-06-17"
    description = "Detects Python bytecode masquerading as a .cat file consistent with reported NarwhalRAT config.cat staging"
    reference = "https://www.genians.co.kr/en/blog/threat_intelligence/narwhalrat"
    confidence = "medium"
  strings:
    $pyc_magic = { 6F 0D 0D 0A }
    $code_obj = { E3 }
    $seed = "aHAnLLtQrP8Ce" ascii
    $pcloud1 = "folderid" ascii wide
    $pcloud2 = "api.pcloud" ascii wide
    $naver = "naverwhale" ascii wide
    $cmd1 = "startscap:" ascii wide
    $cmd2 = "usb2local:" ascii wide
  condition:
    (uint32(0) == 0x0A0D0D06F and any of ($seed,$pcloud*,$naver,$cmd*)) or
    (filename matches /(?.i).*\cat$/ and $pyc_magic at 0 and $code_obj in (8..32))
}

```

```

// Microsoft Defender XDR: NarwhalRAT staging and persistence process chain
let NarwhalDomains =
dynamic(["webhostingkorea.com", "fe01.co.kr", "daehoat.com", "novel21.co.kr", "crwellfood.com"]);
DeviceProcessEvents
| where Timestamp > ago(30d)
| where
  ProcessCommandLine has_any ("ExecutionPolicy Bypass", "config.cat", "KHjWFcsE.bat",
"MicrosoftUserInterfacePicturesUpdateTackMachine", "UserInerfacePicture", "userscreen.exe",
"naverwhale")
  or (FileName in~ ("powershell.exe", "pwsh.exe", "cmd.exe") and ProcessCommandLine has_any
("curl.exe", "webhostingkorea", "config.cat"))
  or (FileName =~ "schtasks.exe" and ProcessCommandLine has_any ("userscreen.exe", "config.cat",
"MicrosoftUserInterfacePicturesUpdateTackMachine"))
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, FileName,
ProcessCommandLine, AccountName, ReportId
| order by Timestamp desc

```

```

// Microsoft Defender XDR: network connections to reported NarwhalRAT relays or suspicious pCloud use
from Python/runtime processes
let NarwhalDomains =
dynamic(["webhostingkorea.com", "fe01.co.kr", "daehoat.com", "novel21.co.kr", "crwellfood.com"]);
let NarwhalIPs =
dynamic(["121.254.222.10", "121.254.222.80", "211.239.157.126", "218.150.78.198", "218.150.78.231", "61.100.
9.206"]);
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any (NarwhalDomains)
  or RemoteIP in (NarwhalIPs)
  or (RemoteUrl has "api.pcloud.com" and InitiatingProcessFileName in~ ("python.exe", "pythonw.exe",
"userscreen.exe"))
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, RemoteUrl,
RemoteIP, RemotePort, Protocol, AccountName
| order by Timestamp desc

```

13.3 Detection Validation and Blind Spots

The detections above are source-informed and should be validated against local telemetry before being promoted to blocking controls. Expected false positives include legitimate PowerShell scripts that use ExecutionPolicy Bypass, curl-based software

deployment, official Python embedded runtime use by developer tools, and sanctioned pCloud access. However, the combination of LNK ancestry, copied curl, webhostingkorea[.]com, UserInterfacePicture, userscreen.exe, config.cat, a one-minute scheduled task, and %APPDATA%\naverwhale should be rare in enterprise environments.

Blind spots include sample variants that change task names, file paths, relay domains, command prefixes, or the Python runtime version. Network-only controls may also miss pCloud dead-drop behavior when TLS inspection is unavailable. Memory-resident final payload activity may not produce a distinct child-process tree, so EDR memory behavior, module loads, API calls, and process network telemetry should be correlated with the earlier staging chain.

14.1 Hunt Hypotheses

- A user received a Microsoft-themed security advisory lure and executed a ZIP-delivered LNK that spawned cmd.exe or PowerShell with obfuscated arguments.
- A compromised host installed the official Python embedded runtime below a public account-picture-themed path and persisted it through a suspicious scheduled task.
- NarwhalRAT established a working directory named naverwhale and staged collected data locally before upload.
- The final payload communicated with known Korean relays or accessed pCloud API from an unmanaged Python process.
- The operator activated keylogging, screen capture, USB collection, or command execution functions after initial persistence.

14.2 Hunt Queries

```
// Hunt 1: archive/LNK-style process chain that stages NarwhalRAT components
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe", "curl.exe", "tar.exe", "schtasks.exe")
| where ProcessCommandLine has_any ("ExecutionPolicy", "Bypass", "KHjWFcsE.bat", "config.cat",
"Python-3.10.0-embed-amd64.zip", "webhostingkorea", "UserInterfacePicture",
"MicrosoftUserInterfacePicturesUpdateTaskMachine")
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Commands=make_set(ProcessCommandLine,
20), Parents=make_set(InitiatingProcessFileName, 10) by DeviceName, AccountName, FileName
| order by LastSeen desc

// Hunt 2: disguised Python runtime and bytecode artifacts
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any ("UserInterfacePicture", "AccountPictures", "naverwhale", "Microsoft\
\Internet Explorer")
    or FileName in~ ("userscreen.exe", "config.cat")
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, SHA256, InitiatingProcessFileName,
InitiatingProcessCommandLine, AccountName
| order by Timestamp desc

// Hunt 3: scheduled task creation for recurring userscreen.exe config.cat execution
DeviceEvents
| where Timestamp > ago(30d)
| where ActionType has_any ("ScheduledTaskCreated", "ScheduledTaskUpdated")
    or AdditionalFields has "MicrosoftUserInterfacePicturesUpdateTaskMachine"
    or AdditionalFields has "userscreen.exe"
    or AdditionalFields has "config.cat"
| project Timestamp, DeviceName, ActionType, AdditionalFields, InitiatingProcessFileName,
InitiatingProcessCommandLine, AccountName
| order by Timestamp desc

// Hunt 4: known NarwhalRAT infrastructure and pCloud API from suspicious processes
let NarwhalDomains =
dynamic(["webhostingkorea.com", "fe01.co.kr", "daehoat.com", "novel21.co.kr", "crwellfood.com"]);
let NarwhalIPs =
dynamic(["121.254.222.10", "121.254.222.80", "211.239.157.126", "218.150.78.198", "218.150.78.231", "61.100.
9.206"]);
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any (NarwhalDomains)
    or RemoteIP in (NarwhalIPs)
    or (RemoteUrl has "api.pcloud.com" and InitiatingProcessCommandLine has_any ("python", "userscreen",
"config.cat", "UserInterfacePicture"))
```

summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), RemoteUrls=make_set(RemoteUrl, 20), RemoteIPs=make_set(RemoteIP, 20), Processes=make_set(InitiatingProcessCommandLine, 20) by DeviceName, AccountName
order by LastSeen desc
index=endpoint (process_name=powershell.exe OR process_name=cmd.exe OR process_name=curl.exe OR process_name=schtasks.exe OR process_name=userscreen.exe)
("ExecutionPolicy Bypass" OR "KHjWFcsE.bat" OR "config.cat" OR "UserInterfacePicture" OR "MicrosoftUserInterfacePicturesUpdateTackMachine" OR "webhostingkorea")
stats min(_time) as first_seen max(_time) as last_seen values(parent_process_name) as parents values(process) as commands by host user process_name
convert ctime(first_seen) ctime(last_seen)

14.3 Triage Guidance for Hunt Hits

A meaningful hit is a correlated sequence, not just one weak signal. Escalate quickly when a host shows LNK or archive ancestry, PowerShell ExecutionPolicy Bypass, curl staging from external domains, creation of UserInterfacePicture or config.cat, scheduled-task creation, and subsequent network traffic to listed relays or pCloud. Isolated pCloud access may be benign; pCloud access by userscreen.exe, pythonw.exe from public profile paths, or a process launched by an unusual scheduled task is high risk.

When a hunt returns hits, collect the LNK file, ZIP attachment, BAT script, config.cat, scheduled-task XML, PowerShell operational logs, Prefetch/Amcache/Shimcache, EDR process tree, DNS/proxy logs, and any files under %APPDATA%\naverwhale. Preserve volatile memory if the host is still active because the final payload may execute in memory without a standalone PE file on disk.

15. Triage and Incident Response

Treat confirmed NarwhalRAT activity as an active espionage intrusion. The malware supports remote commands, file collection, USB collection, keylogging, screen capture, and audio capture; containment should therefore include both endpoint and identity scoping.

Priority	Action	Owner	Rationale
Critical	Isolate affected endpoint from the network while preserving volatile evidence when feasible	SOC / IR	Prevent further operator control and exfiltration while retaining in-memory payload evidence
Critical	Disable or delete the scheduled task only after collecting task XML, command line, and related files	IR	Persistence artifact is high-value evidence for chain reconstruction
High	Acquire ZIP, LNK, BAT, config.cat, userscreen.exe, .ent config, and naverwhale working directory	Forensics	Enables hash enrichment, config recovery, and data-loss assessment
High	Reset credentials for the affected user and review MFA/session tokens	IAM	Keylogging and screen capture may expose credentials or OTP flows
High	Search adjacent hosts for task name, paths, MD5s, domains, and IPs	SOC	Campaign may have targeted multiple users with similar lure
Medium	Review email gateway logs for the lure subject, attachment names, and sender domain	Messaging / SOC	Identifies recipients, clicks, and additional exposed users
Medium	Review proxy/DNS/firewall	Network Security	Establishes timeline and data-

	logs for relay and pCloud traffic		exfiltration likelihood
Medium	Notify users in relevant Korean-language / Korea-facing business units of the lure pattern	Security Awareness	Reduces follow-on execution while investigation proceeds

Containment should not stop at deleting config.cat or blocking listed domains. If keylogging or file collection was enabled, assume credential and sensitive-data exposure until disproven. If pCloud traffic occurred after scheduled-task persistence, scope for exfiltration and validate whether sanctioned cloud-storage policies were bypassed.

16. Validation and Emulation

Validation completed for this report:

Validation Area	Status	Notes
Primary-source review	Completed	Genians report reviewed for execution chain, code findings, C2, commands, persistence, and IOCs
Secondary-source review	Completed	The Hacker News intake source reviewed for public summary and attribution context
Local sandbox execution	Not performed	No sample was provided to Lost Boys Cyber
Static file inspection	Not performed locally	Public MD5s available; no binary for hashing, YARA validation, or PE metadata extraction
Code/decompiler review	Not performed locally	Genians decompilation findings cited and clearly attributed
Detection logic validation	Draft / source-informed	Sigma, YARA, KQL, and SPL require local testing before production blocking

Safe emulation can validate defensive coverage without executing malware:

- Create a benign test LNK that launches cmd.exe and PowerShell with an ExecutionPolicy Bypass string and harmless curl request to an internal sinkhole, then verify process-chain detections.
- Run a controlled schtasks command creating a benign task name containing MicrosoftUserInterfacePicturesUpdateTaskMachine against a test executable, then verify task-creation telemetry.
- Place a harmless file named config.cat with Python bytecode magic in a lab directory and test YARA/file-scanning coverage.
- Generate synthetic DNS/proxy events for the defanged domains using a test host or SIEM replay, then validate correlation rules.
- Execute a benign Python process named userscreen.exe in a lab path containing UserInterfacePicture and verify EDR command-line detections.

Do not emulate collection, keylogging, microphone recording, or pCloud upload behavior on production endpoints. Where behavior emulation is needed, use a closed lab and non-sensitive test data.

17. Recommendations

Priority	Owner	Action	Rationale
Critical	SOC / Detection Engineering	Deploy source-informed detections for LNK-to-	These are the most durable and

		PowerShell/curl, UserInterfacePicture, userscreen.exe config.cat, and the scheduled-task name	actionable observed behaviors
Critical	Email Security	Block or detonate ZIP archives containing LNK files; add Microsoft Account OTP lure patterns to phishing triage	The initial vector depends on user execution of a shortcut disguised as an advisory
High	EDR Platform Team	Ensure full command-line, parent/child process, scheduled-task, file-create, and network telemetry are retained for at least 30-90 days	The attack requires multi-event correlation across several stages
High	Network Security	Add temporary blocks and monitoring for listed relays and IPs; alert on pCloud API use by unmanaged Python processes	Infrastructure is known but may rotate; behavior around pCloud is more resilient
High	IT / Endpoint Engineering	Restrict script execution from user-writable archive/temp paths and monitor copied LOLBins such as curl.exe	Reduces the usefulness of the current staging chain
High	IAM	Strengthen MFA fatigue/OTP education and monitor account activity for users who received the lure	The lure abuses trust in account-security notifications and may expose credentials
Medium	Threat Hunting	Run the included 30-day KQL/SPL hunts across endpoint, email, proxy, DNS, and firewall data	Identifies historical exposure and confirms whether NarwhalRAT reached persistence
Medium	Forensics	Build a collection package for ZIP/LNK/BAT/config.cat/.ent/n averwhale/task XML artifacts	Enables rapid response if an endpoint hit is found
Medium	Security Awareness	Warn Korea-facing users about fake Microsoft security notices carrying ZIP/LNK attachments	Targeting signals suggest Korean-language or Korean-service users are most exposed
Low	CTI	Track Genians/ScarCruft reporting for updated hashes, C2, and variants	IOCs are likely to age; TTP tracking should continue

18. References and Refresh Notes

- [1] Genians Security Center, Analysis of APT37 NarwhalRAT Leveraging MS-Themed Phishing and Dead-drop C2, published 2026-06-14, https://www.genians.co.kr/en/blog/threat_intelligence/narwhalrat
- [2] The Hacker News, Fake Microsoft Alerts Used to Deploy North Korean NarwhalRAT Malware, published 2026-06-16, <https://thehackernews.com/2026/06/fake-microsoft-alerts-used-to-deploy.html>
- [3] MITRE ATT&CK Enterprise Matrix, technique references used for defensive mapping, <https://attack.mitre.org/>

Refresh notes:

- Re-check Genians for updated SHA256 hashes, YARA, or additional infrastructure before publication to a client package.
- Re-score domains and IPs before long-term blocking; relay infrastructure may be cleaned, sinkholed, or repurposed.
- If a sample becomes available, perform independent static, dynamic, and Ghidra-assisted review and update Sections 2, 5, 6, 7, and 16 with observed hashes, file sizes, compile metadata, strings, config offsets, screenshots, packet captures, and process telemetry.
- If internal telemetry finds hits, add tenant-specific timelines, affected users, hostnames, and containment status in an incident-specific appendix rather than modifying the public TLP:CLEAR intelligence baseline.